

Final Report

External Penetration Testing Assessment Report

Prepared For:

PosBuzz Retail Solutions

Prepared By: K.M.Reyazul Jhanna Shaon

Name: K.M.Reyazul Jhanna Shaon

Student ID: 2023200000275

Serial Number: 09

Course:

Applied Penetration Testing Engineer

Submission Date: 18 May 2026

Section 1 — Executive Summary

The following report provides an overview of the results obtained during three security exercise sessions on Active Reconnaissance, OWASP Juice Shop, and Blue (MS17-010) vulnerable machine. The assessments reveal that poor configuration, poor coding techniques, and unpatched systems can pose serious security threats. In all scenarios, there was room for attackers to obtain information leakage, perform authentication bypass, and carry out system compromise attacks.

Section 2 — Scope of Assessment

In Scope:

- TryHackMe Active Reconnaissance Room
- OWASP Juice Shop Vulnerable Web Application
- Blue (MS17-010 / EternalBlue) Windows Machine

Out of Scope:

- Real production systems
- External third-party infrastructure
- Denial of Service (DoS) testing

Section 3 — Methodology

The assessment was conducted using a formal penetration test process involving five phases:

Phase 1: Reconnaissance – Finding alive hosts and gathering information.

Phase 2: Vulnerability Assessment – Discovering the vulnerabilities in the application or service.

Phase 3: Exploitation – Trying to exploit the identified vulnerability.

Phase 4: Post-Exploitation – Elevating privileges and extracting data.

Section 4 — Active Reconnaissance

Summary Tools: Ping, traceroute, telnet, netcat, and DevTools.

Observations:

- Header info leaks, SSL info leakage, and JavaScript files
- ICMP replies indicated host status and OS info
- Network paths indicated internal network routing
- Banner grabbing showed service version information

Impact:

- The attacker can learn about the target system in advance to exploit vulnerabilities – Network mapping is more precise

Mitigation:

- Remove unnecessary banners and metadata leaks
- Control ICMP and traceroute replies
- Replace Telnet and other insecure protocols with SSH

Section 5 — OWASP Juice Shop Summary

Findings:

- Information leakage via application features
- Broken authentication resulting in login bypass
- SQL injection vulnerabilities in login forms

Impact:

- Account takeover
- Data leakage and risk of data exfiltration

- Privilege escalation to administrative level

Mitigation strategies:

- Adopting prepared statements
- Input validation/sanitization
- Secure authentication techniques

Section 6 — Blue Room Summary

Vulnerability: MS17-010 (EternalBlue SMB Vulnerability)

Findings:

- Open SMB service on port 445
- Remote code execution through EternalBlue attack
- Privilege escalation to SYSTEM level
- Credentials hash dump and crack

Consequence:

- Complete system takeover
- Credential stealing for lateral movement
- Access to sensitive system files

Mitigation:

- Patch MS17-010 vulnerability
- Dismantle SMBv1
- Limit port 445 connection
- Activate credential safeguards

Section 7 — General Remediation

Recommendations - Make sure that systems and applications are completely updated

- Adopt secure coding techniques (input validation, parameterized queries) - Disable old and insecure protocols
- Continuous monitoring and logging - Perform vulnerability assessments

Section 8 — Conclusion

These examples show how common weaknesses that exist in web applications, network services, and legacy systems can result in significant compromise. Good security hygiene, proper software development, and effective patching are necessary to prevent such incidents.